Implantación de un SIEM con ELK y demostración de un incidente

Volodimir Yarmash Yarmash

Objetivo.....1
Requisitos.....2
1. SIEM:.....2
2. Víctima.....2
3. Ataques / Incidentes.....2
4. Evidencias en ELK.....2
Evaluación (APTO / NO APTO).....5
APTO.....5
NO APTO.....5
Entrega de la práctica.....5

Objetivo

El alumno debe ser capaz de montar desde cero un SIEM basado en ELK usando Docker, crear una máquina víctima, provocar un incidente de seguridad sobre ella y demostrar en Kibana que dicho incidente queda reflejado correctamente.
La práctica no tiene una solución única. Cada alumno decide cómo lo monta y qué tipo de incidente genera.
No se evalúa que el sistema sea perfecto ni completo, sino que sea funcional.
Se evalúa que el alumno comprenda y sea capaz de explicar el funcionamiento del SIEM implantado, el flujo de los logs y la naturaleza del incidente o vulnerabilidad demostrada.

Requisitos

1. SIEM:

Debe desplegarse un SIEM en Docker que incluya:

- Elasticsearch
- Kibana
- Un mecanismo de ingesta de logs (Logstash y/o Beats)

El SIEM debe estar operativo y accesible.

2. Víctima

El alumno debe crear una o varias máquina o servicio víctima que:

- Genere logs de forma observable
- Permita identificar eventos relevantes

La víctima puede ser:

- un servicio de login
- un servicio web
- tráfico de red
- firewall
- ICMP, conexiones, accesos, etc.

La elección es libre.

3. Ataques / Incidentes

Debe ejecutarse al menos un ataque o incidente intencionado sobre la víctima, por ejemplo:

- múltiples intentos de login
- ráfaga de accesos
- escaneo de puertos
- flood de ICMP
- cualquier acción repetitiva que genere eventos

El ataque debe ser:

- realizado sobre el propio entorno
- reproducible
- claramente identificable en el tiempo

4. Evidencias en ELK

El alumno debe demostrar en Kibana:

- que los logs llegan al SIEM
- que el incidente genera un patrón claro
- que se pueden identificar al menos:
    - o el origen del evento

- o el tipo de evento
- o el momento en el que ocurre

No es obligatorio crear dashboards ni alertas.

5. Realizacion

Una vez tenemos nuestro docker desktop instalado y bien configurado, tenemos que empezar por el archivo de configuración docker-compose y de filebeat.

Creamos una carpeta para nuestro proyecto y creamos los archivos .yml

Nombre	Fecha de modificación	Tipo	Tamaño
docker-compose.yml	10/03/2026 18:06	Archivo de origen ...	2 KB
filebeat.yml	10/03/2026 18:06	Archivo de origen ...	1 KB

El archivo docker-compose.yml es el orquestador. Su función es definir y conectar los cuatro pilares de tu laboratorio en una red aislada de Docker. Esta es la estructura que lleva:

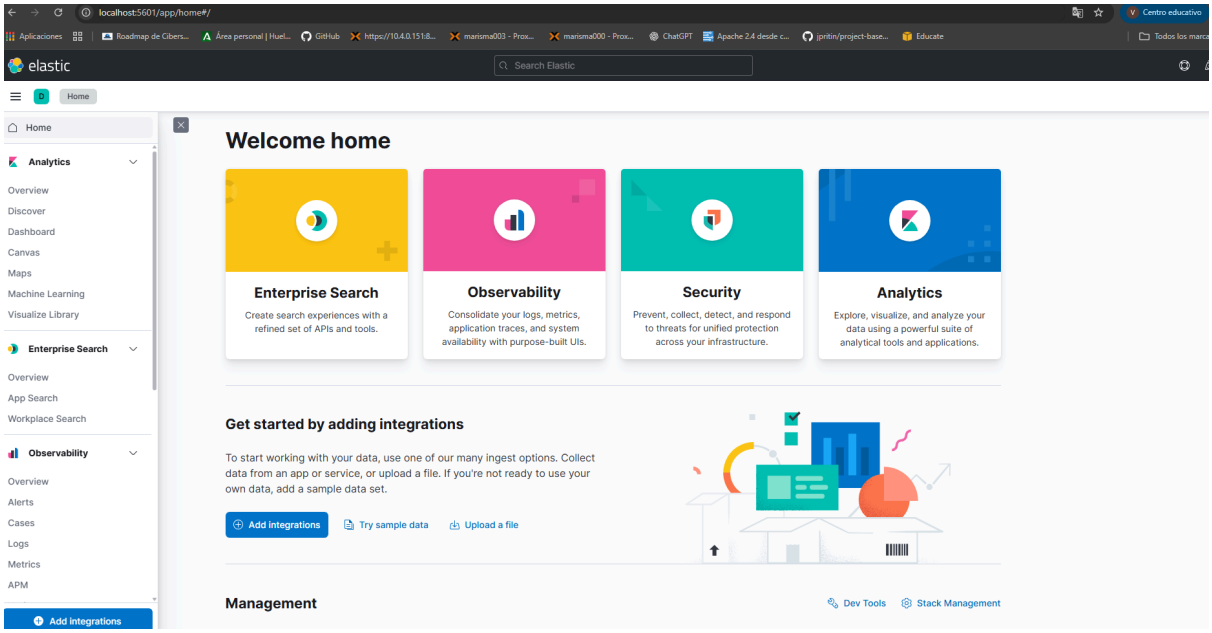
elasticsearch: Actúa como la base de datos NoSQL orientada a documentos donde se indexan y almacenan los logs para que las búsquedas sean instantáneas.

kibana: Es la interfaz gráfica. Se conecta a Elasticsearch para visualizar los datos, realizar búsquedas y generar los gráficos del incidente.

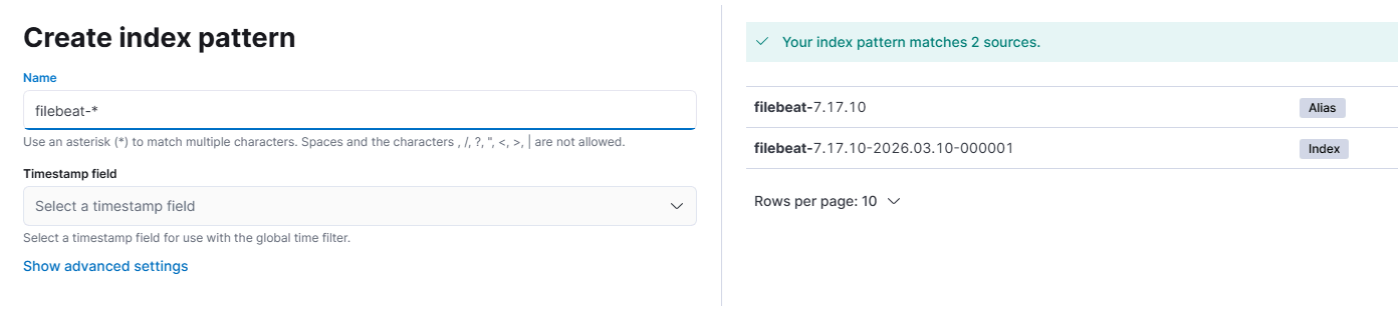
victima-web: Es un servidor web real. Está configurado con un volumen compartido (logs-web) para que sus archivos de log sean accesibles desde fuera del contenedor.

filebeat: Es el agente de transporte. Tiene acceso al mismo volumen de logs que la víctima. Su trabajo es "leer" los logs en tiempo real y "empujarlos" hacia Elasticsearch.

Una vez lo tengamos todo, arrancamos docker con el comando docker-compose up -d al abrir el terminal en la carpeta del proyecto.
Cuando lo tengamos ya todo ejecutado de forma correcta. en el puerto 5601 ya tenemos nuestra aplicación disponible:



Nos dirigimos por esta ruta (Management -> Stack Management -> Index Patterns) hasta llegar a opción de crear un pattern.
Agregamos la etiqueta filebeat-*

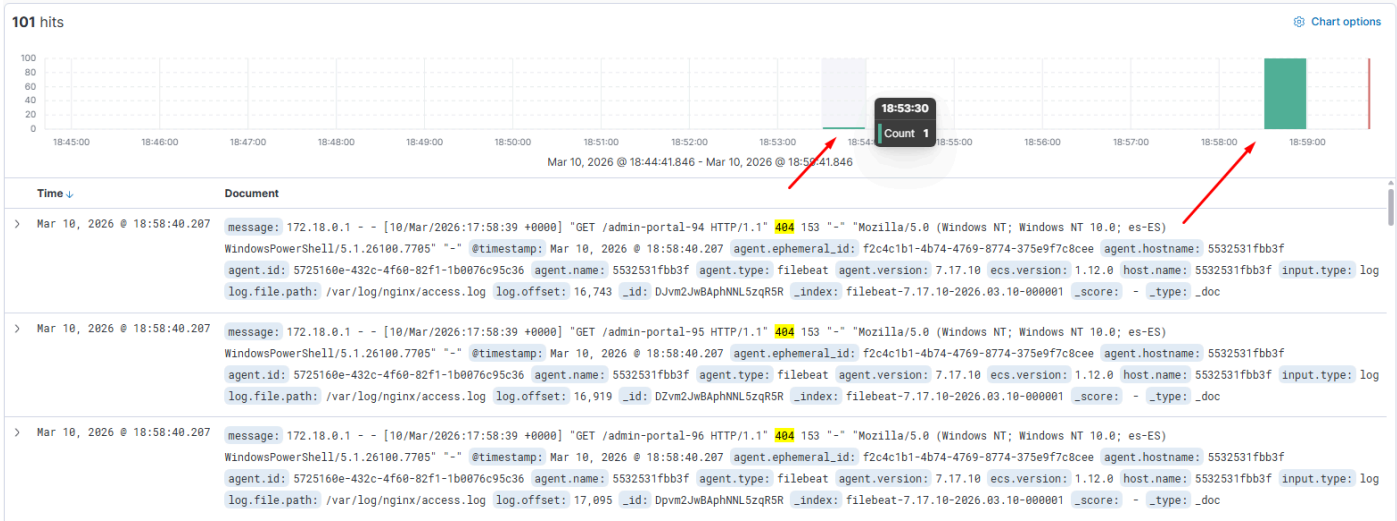


Ya tengo el motor del SIEM funcionando, ahora vamos a hacer una prueba de fuerza bruta.
Para ello vamos a generar peticiones con el powershell:

```
for ($i=1; $i -le 100; $i++) { curl http://localhost:8080/admin-portal-$i }
```

```
PS C:\Users\vladt> for ($i=1; $i -le 100; $i++) { curl http://localhost:8080/admin-portal-$i }
curl : 404 Not Found
nginx/1.29.5
En línea: 1 Carácter: 32
+ ... i=1; $i -le 100; $i++) { curl http://localhost:8080/admin-portal-$i }
+                              ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : InvalidOperation: (System.Net.HttpWebRequest:HttpWebRequest) [Invoke-WebRequest], WebExc
   eption
    + FullyQualifiedErrorId : WebCmdletWebResponseException,Microsoft.PowerShell.Commands.InvokeWebRequestCommand
curl : 404 Not Found
nginx/1.29.5
En línea: 1 Carácter: 32
+ ... i=1; $i -le 100; $i++) { curl http://localhost:8080/admin-portal-$i }
+                              ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : InvalidOperation: (System.Net.HttpWebRequest:HttpWebRequest) [Invoke-WebRequest], WebExc
   eption
    + FullyQualifiedErrorId : WebCmdletWebResponseException,Microsoft.PowerShell.Commands.InvokeWebRequestCommand
curl : 404 Not Found
nginx/1.29.5
En línea: 1 Carácter: 32
+ ... i=1; $i -le 100; $i++) { curl http://localhost:8080/admin-portal-$i }
+                              ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : InvalidOperation: (System.Net.HttpWebRequest:HttpWebRequest) [Invoke-WebRequest], WebExc
   eption
    + FullyQualifiedErrorId : WebCmdletWebResponseException,Microsoft.PowerShell.Commands.InvokeWebRequestCommand
```

Como podemos ver, en elastic aparece con un pico visible en el gráfico:



Evaluación (APTO / NO APTO)

La evaluación será presencial y práctica.
El alumno deberá:

1. Arrancar el entorno en Docker
2. Explicar brevemente la arquitectura:
   o qué contenedores hay
   o cómo llegan los logs a ELK
   o cualquier otra información relevante
3. Ejecutar el ataque/incidente
4. Mostrar el resultado en Kibana
5. Explicar qué está ocurriendo

APTO

- El SIEM funciona
- El incidente se ve claramente en Kibana
- El alumno entiende y explica lo que ha montado

NO APTO

- No llegan logs
- No se identifica el incidente
- No sabe explicar su propio montaje
- Ha copiado sin comprender

Entrega de la práctica

Para que la práctica pueda ser calificada, será obligatoria la entrega de dos ficheros. La

ausencia de cualquiera de ellos implicará que la práctica no pueda evaluarse.
El alumno deberá entregar:

1. Fichero docker-compose.yml
   o Debe permitir reproducir el entorno completo del SIEM, la víctima y el ataque/incidente.
2. Documento en formato PDF, que incluirá:
   o Explicación de la arquitectura montada.
   o Capturas de pantalla que evidencien:

▪ el entorno levantado en Docker,
▪ la ejecución del ataque/incidente,
▪ la visualización de los eventos en Kibana.

o Explicaciones necesarias que permitan verificar el funcionamiento del SIEM y la identificación del incidente.

La documentación deberá ser clara y suficiente para permitir la verificación del funcionamiento, sin perjuicio de la evaluación presencial y práctica, que será determinante.